

DLP trong Big Data

Ngăn ngừa rò rỉ dữ liệu

Giảng viên hướng dẫn:
PGS.TS. Đặng Trần Khánh
TS. Phạm Thị Bạch Huệ
ThS. Lương Vĩ Minh

25C12011 - Nguyễn Bảo Trâm
25C11012 - Võ Công Minh
25C12016 - Trần Huy Vũ
25C12031 - Dương Tấn Huỳnh Phong

Date: 29/09/2026

Mục Lục



1. Bài toán bảo mật Big Data



2. Cơ chế DLP trong Big Data



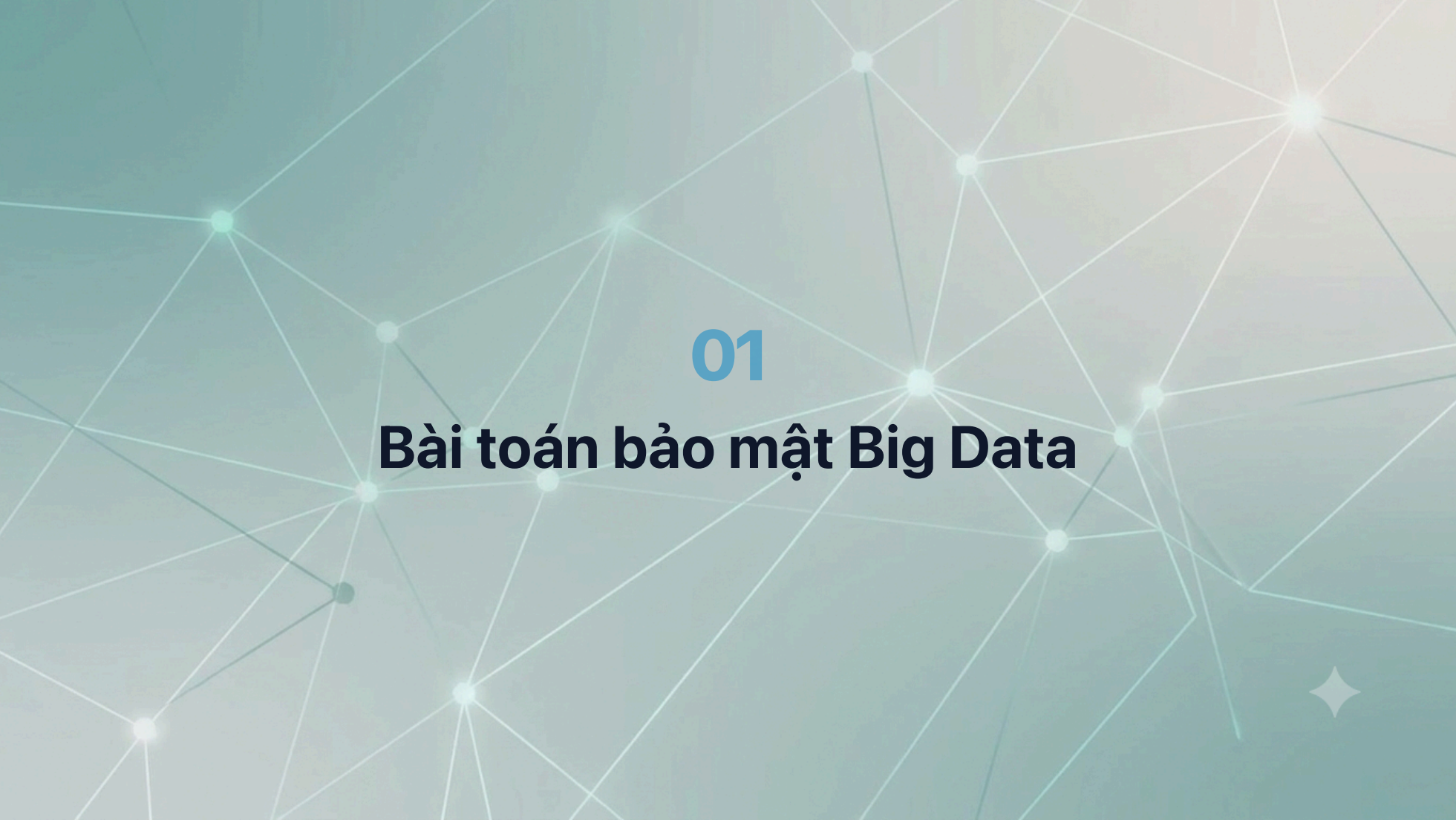
3. Giải pháp và xu hướng DLP



4. Demo và đánh giá



5. Giới hạn và kết luận



01

Bài toán bảo mật Big Data

Big Data: Luồng dữ liệu & Nguy cơ rò rỉ

Đặc thù khối lượng lớn, tốc độ cao và đa dạng (3V) — dữ liệu luân chuyển liên tục qua nhiều tầng xử lý để tạo ra các bảng tổng hợp phục vụ phân tích.



1. Quyền truy cập (Access Control)

Xác thực người dùng và phân quyền đọc/ghi trên các cụm dữ liệu phân tán.

2. Tính toàn vẹn (Integrity)

Đảm bảo dữ liệu không bị sửa đổi trái phép trong quá trình truyền tải và tính toán.

3. Tính sẵn sàng (Availability)

Duy trì hạ tầng lưu trữ và dịch vụ phân tích luôn sẵn sàng phục vụ người dùng.

4. Rò rỉ dữ liệu (Data Leakage) — Trọng tâm

Dữ liệu nhạy cảm sau xử lý bị gửi nhầm nơi nhận hoặc thất thoát ra bên ngoài.

Đọc đúng quyền, nhưng gửi sai đích?

Tình huống thực tế: Người dùng thực hiện thao tác nghiệp vụ hợp lệ nhưng vẫn tạo ra nguy cơ rò rỉ dữ liệu.



1. Thao tác nghiệp vụ hợp lệ

Chuyên viên dữ liệu được cấp quyền đọc thông tin khách hàng từ Data Lake.

Chạy truy vấn tạo bảng tổng hợp `customer_segments` để phục vụ công việc.

⚠ Bảng kết quả sau xử lý vô tình vẫn còn thông tin định danh cá nhân: **Mã KH, Email, SĐT (PII)**.

2. Nguy cơ khi chia sẻ ra ngoài

Tập dữ liệu này được xuất và gửi sang **kênh bên ngoài chưa được kiểm duyệt** (đám mây cá nhân, đối tác).

Điểm mù bảo mật: Hệ thống chỉ kiểm soát quyền lúc đọc vào, nhưng bỏ ngỏ nội dung tập khi xuất ra ngoài!

Làm sao tự động nhận diện PII trong tập gửi đi để ngăn chặn kịp thời? → Đó là vai trò của DLP.

5 / 22

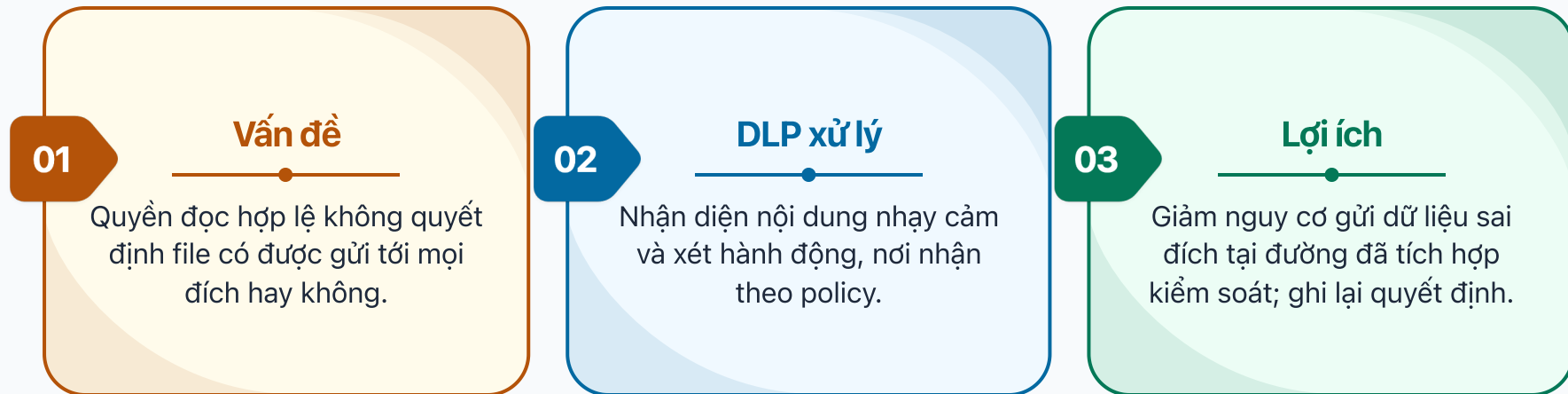


02

Cơ chế DLP trong Big Data

DLP là gì?

Data Loss Prevention (DLP) nhận diện dữ liệu nhạy cảm và áp dụng policy để kiểm soát việc sử dụng, chia sẻ hoặc xuất dữ liệu.

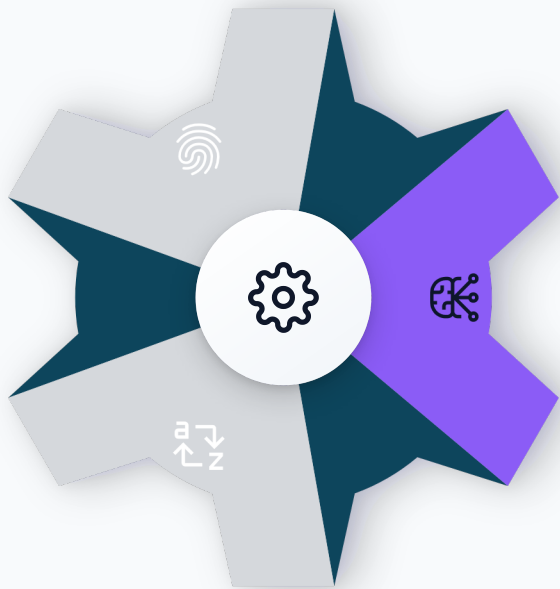


DLP trong Defense-in-Depth (DiD)



DLP bổ sung kiểm soát nội dung và cách chia sẻ dữ liệu tại nhiều lớp.

Ba cách tìm nội dung nhạy cảm



Ngữ cảnh (AI/ML)

Phân loại theo ngữ cảnh

Cơ chế: Dùng mô hình để đánh giá nội dung trong ngữ cảnh.

Ví dụ: Câu tiết lộ thông tin sức khỏe.

Giới hạn: Có thể báo nhầm hoặc bỏ sót; cần đánh giá trên dữ liệu thực tế.

Phát hiện cung cấp đầu vào cho policy; chặn cần điểm thực thi.

DLP trong pipeline Big Data



Chặn chỉ có hiệu lực tại đường đã tích hợp kiểm soát.

Thách thức: quy mô lớn · đa định dạng · dữ liệu biến đổi · nhiều đường xuất.



03

Giải pháp và xu hướng DLP

Giải pháp DLP cho Big Data

Phân quyền, masking và audit là nền tảng; DLP bổ sung kiểm soát dữ liệu nhạy cảm.

	Amazon Macie Amazon S3	Microsoft Purview DLP Fabric / Power BI	Sensitive Data Protection Google Cloud
Phạm vi	Đối tượng S3 được hỗ trợ.	Các loại mục và dữ liệu được hỗ trợ trong Fabric / Power BI.	BigQuery, Cloud Storage và dữ liệu gửi qua API.
Khả năng chính	Khám phá dữ liệu nhạy cảm ; tạo findings.	Policy tips, cảnh báo ; hạn chế truy cập (preview).	Kiểm tra dữ liệu nhạy cảm ; khử định danh.
Ranh giới kiểm soát	Findings cần gắn với quy trình xử lý hoặc biện pháp thực thi.	Hạn chế truy cập vào mục; không bao phủ mọi đường xuất.	Kiểm tra và khử định danh cần tích hợp vào luồng dữ liệu.

Phát hiện, khử định danh và hạn chế truy cập là các khả năng khác nhau.

AI hỗ trợ DLP ở đâu?

HỖ TRỢ HUẤN LUYỆN

Tạo dữ liệu tổng hợp

LLM tạo văn bản tiếng Ý để huấn luyện mô hình phát hiện dữ liệu nhạy cảm.

LLM → Văn bản tổng hợp → Huấn luyện bộ phát hiện

De Renzis, Dosso & Testolin · 2024 ^[1]

HỖ TRỢ PHÁT HIỆN

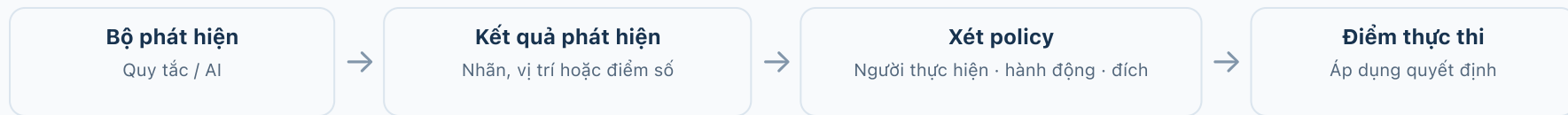
Nhận diện theo ngữ cảnh

Nhận diện thông tin nhạy cảm phụ thuộc ngữ cảnh trong văn bản phi cấu trúc.

Trọng tâm: nội dung nhạy cảm trong ngữ cảnh sử dụng.

Qawara & Alhindi · 2026 ^[2]

Minh họa tích hợp trong DLP



Cần đánh giá lại trên dữ liệu đích: báo nhầm, bỏ sót và độ trễ.



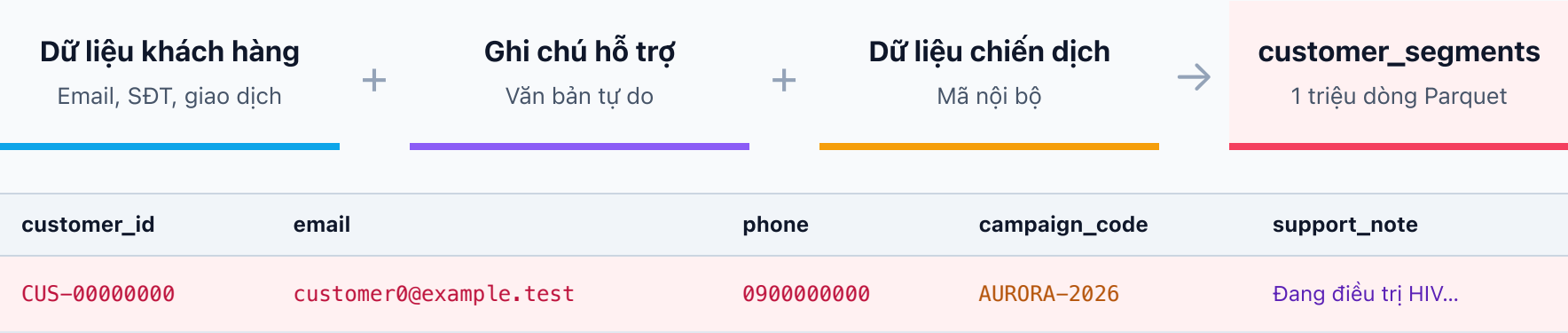
04

Demo và đánh giá



Tình huống: gửi dữ liệu phân khúc cho đối tác

Phong là chuyên viên dữ liệu của một công ty bán lẻ. Phong được phép đọc dữ liệu khách hàng và chạy Spark để tạo bảng phân khúc cho một chiến dịch marketing.



Kiểm soát hiện có: Phong đăng nhập đúng tài khoản và có quyền đọc Data Lake.

Vấn đề: quyền đọc không cho biết file này có được gửi sang ổ đĩa của đối tác hay không.

DLP phát hiện những gì trong file?

Nội dung	Cách phát hiện	Kết quả quét	Nhãn
Email, SĐT và mã khách hàng	Tên cột và quy tắc định dạng	1.000.000 dòng	PII
Mã AURORA-2026	So khớp fingerprint SHA-256 đã đăng ký	5 dòng	Chiến dịch nội bộ
"Đang điều trị HIV..."	Mô hình phân loại theo ngữ cảnh	5 dòng	Thông tin sức khỏe

Quy tắc định dạng phù hợp với email và số điện thoại. Nó không hiểu ý nghĩa của một câu văn. Mô hình ngữ cảnh bổ sung phần còn thiếu đó.

Mô hình trong demo được huấn luyện bằng một tập câu tổng hợp nhỏ. Nó chỉ minh họa cách đưa AI vào bước phát hiện, chưa đủ để dùng trong hệ thống thật.

Kết quả quét chỉ là đầu vào. Policy mới quyết định file có được gửi đi hay không.

Nơi nhận quyết định cách xử lý file

Policy xét người gửi, hành động, nhãn dữ liệu và nơi nhận. Ba lần chạy dưới đây dùng cùng một export gateway.

File gửi đi	Nơi nhận	Kết quả	Bảng chứng tại nơi nhận
customer_segments Có PII và dữ liệu nhạy cảm	Kho phân tích nội bộ Đã được duyệt	CHO PHÉP	18 tệp · 19.589.777 byte
customer_segments Giữ nguyên nội dung	Ổ đĩa của đối tác Chưa được duyệt	CHẶN	0 tệp · 0 byte
segment_summary Chỉ còn số liệu tổng hợp	Ổ đĩa của đối tác	CHO PHÉP	4 tệp · 1.384 byte

Đối tác chỉ cần số khách theo vùng và phân khúc. Sau khi file chi tiết bị chặn, nhóm dữ liệu tạo một bảng tổng hợp rồi gửi lại.

Mỗi lần xử lý đều ghi lại người gửi, nơi nhận, policy khớp và số byte đã được ghi.

17 / 22

Demo đã làm đến đâu?

Mức độ	Nội dung
Đã chạy thật	Spark đọc một triệu dòng Parquet, ba cách phát hiện, policy tại cổng xuất, ghi file và nhật ký JSONL.
Chỉ minh họa	Luồng dữ liệu từ nguồn đến bảng dẫn xuất, vị trí của DLP trong Defense-in-Depth và cách AI cung cấp nhãn cho policy.
Chưa triển khai	Kho metadata và lineage tự động, endpoint/network DLP, chặn đường vòng, audit chống sửa đổi và mô hình AI đủ điều kiện triển khai thực tế.

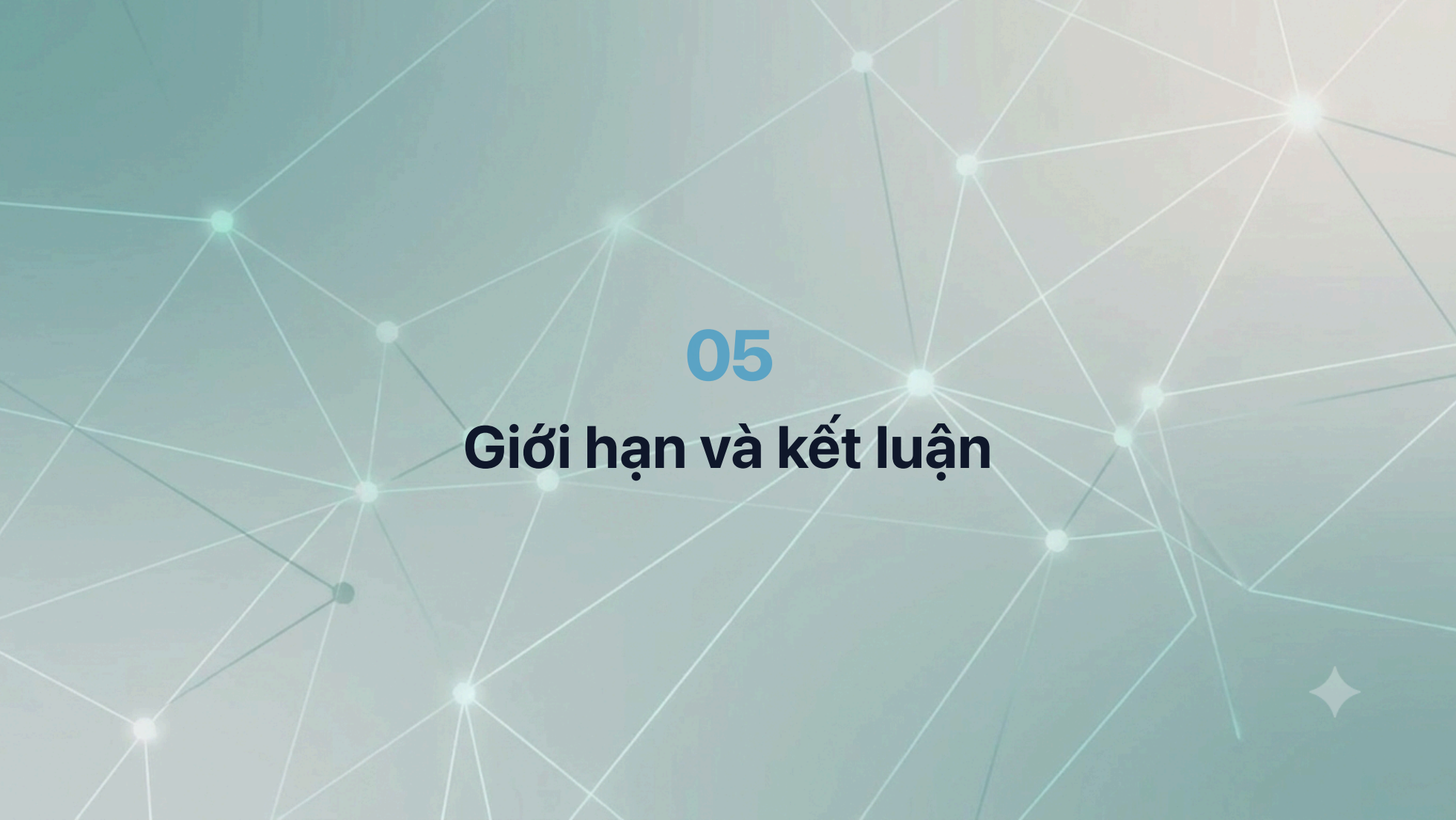
Kết quả kiểm tra

9 test tự động đã chạy qua. Trường hợp bị chặn giải phóng 0 byte.

Cách hiểu đúng kết quả

Demo chạy local trên dữ liệu tổng hợp. Kết quả không đại diện cho độ chính xác hoặc hiệu năng của một hệ thống DLP thực tế.

Demo chứng minh một điểm kiểm soát tại đường xuất. Access control, mã hóa và các lớp bảo vệ khác vẫn cần thiết.



05

Giới hạn và kết luận



Bảo vệ bản dữ liệu dẫn xuất



Phát hiện trong bản dẫn xuất

Quét `customer_segments` , nhận diện các cột `customer_id` và `email`, rồi gắn nhãn nhạy cảm.

Chặn hành động xuất

Chặn lần gửi tập dữ liệu đó tới dịch vụ ngoài chưa được duyệt, tại đúng điểm xuất có kiểm soát.

có thể báo nhầm / bỏ sót

nhãn có thể lỗi thời sau biến đổi

đường xuất không giám sát vẫn là giới hạn

Phân loại bản dẫn xuất; thực thi chính sách tại từng đường xuất được kiểm soát.

References

Alneyadi et al. (2016)

A survey on data leakage prevention systems

Liu et al. (2015)

Privacy-Preserving Scanning of Big Content for Sensitive Data Exposure with MapReduce

Shapira et al. (2013)

Content-based data leakage detection using extended fingerprinting

Ahmed et al. (2021)

Automated detection of unstructured context-dependent sensitive information using deep learning

Schwab et al. (2021)

Performance Evaluation of Policy-Based SQL Query Classification for Data-Privacy Compliance

Herrera Montano et al. (2022)

Survey of Techniques on Data Leakage Protection and Methods to address the Insider threat

De Renzis et al. (2024)

Exploiting Large Language Models to Train Automatic Detectors of Sensitive Data

Qawara & Alhindi (2026)

Detecting Context-Dependent Sensitive Data in Unstructured Text



Thank You
for your attention!